ESERCITAZIONE PRATICA DI SICUREZZA INFORMATICA

Relazione di laboratorio: test di sicurezza e attacchi a dizionario con Hydra

Studente: Simone Meola **Ambiente di test:** Kali Linux (VirtualBox) **Data:** 13 novembre 2026

1. Obiettivo dell'esperienza

In questa attività pratica ho voluto approfondire il funzionamento degli attacchi di tipo *brute-force* basati su dizionario utilizzando lo strumento **Hydra**. Ho strutturato il lavoro dividendolo in due fasi principali, testando prima il protocollo **SSH** e successivamente il protocollo **FTP**, analizzando l'efficacia delle credenziali e le performance dei dizionari.

2. Preparazione dell'ambiente di test

Per operare in sicurezza e simulare uno scenario di test controllato, ho configurato il mio ambiente di lavoro all'interno di una macchina virtuale Kali Linux, sfruttando l'indirizzo di loopback `127.0.0.1`.

Come primo passo operativo ho creato un utente di prova denominato `test_user`, impostando una password semplice (`testpass`) per poter validare il corretto funzionamento degli attacchi in tempi rapidi.

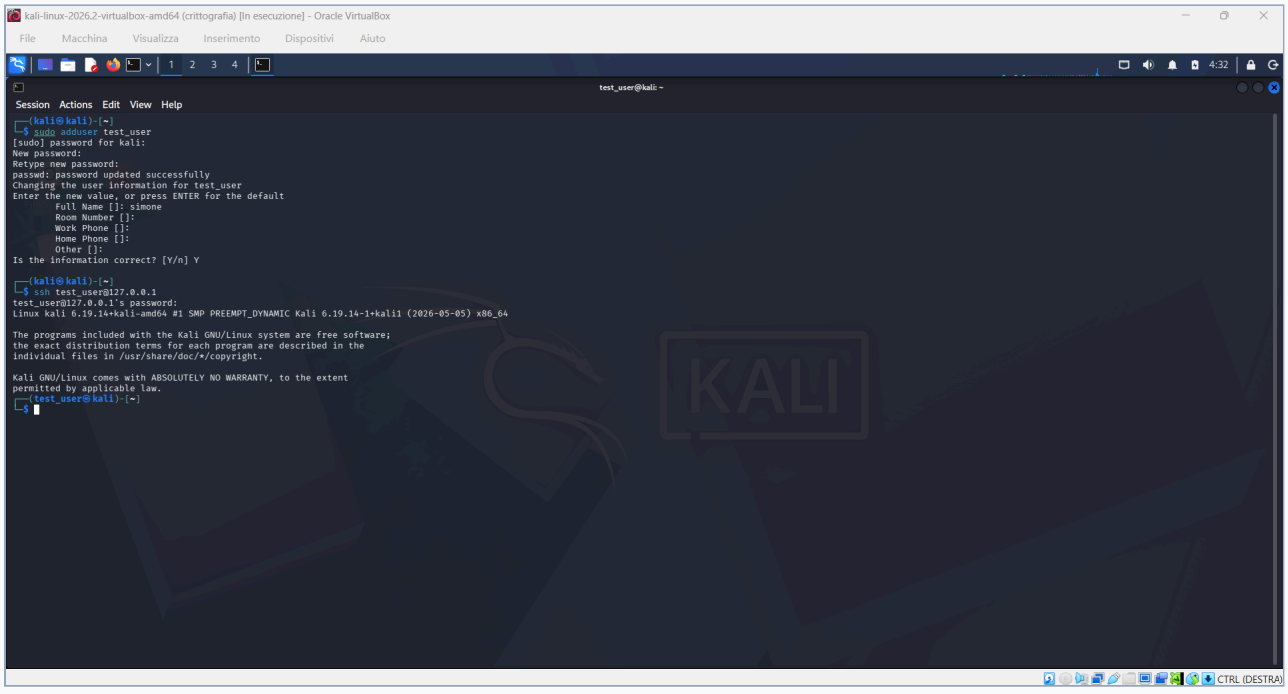


Figura 1: *creazione dell'utente di prova* `test_user` *tramite il comando* `sudo adduser`.

3. Fase 1: abilitazione e test sul servizio SSH

Nella prima fase ho configurato e testato il servizio **SSH** (*Secure Shell*), il protocollo standard utilizzato per amministrare i sistemi Linux da remoto in modo cifrato.

Ho avviato il demone e verificato che il nuovo utente potesse autenticarsi correttamente sul sistema.

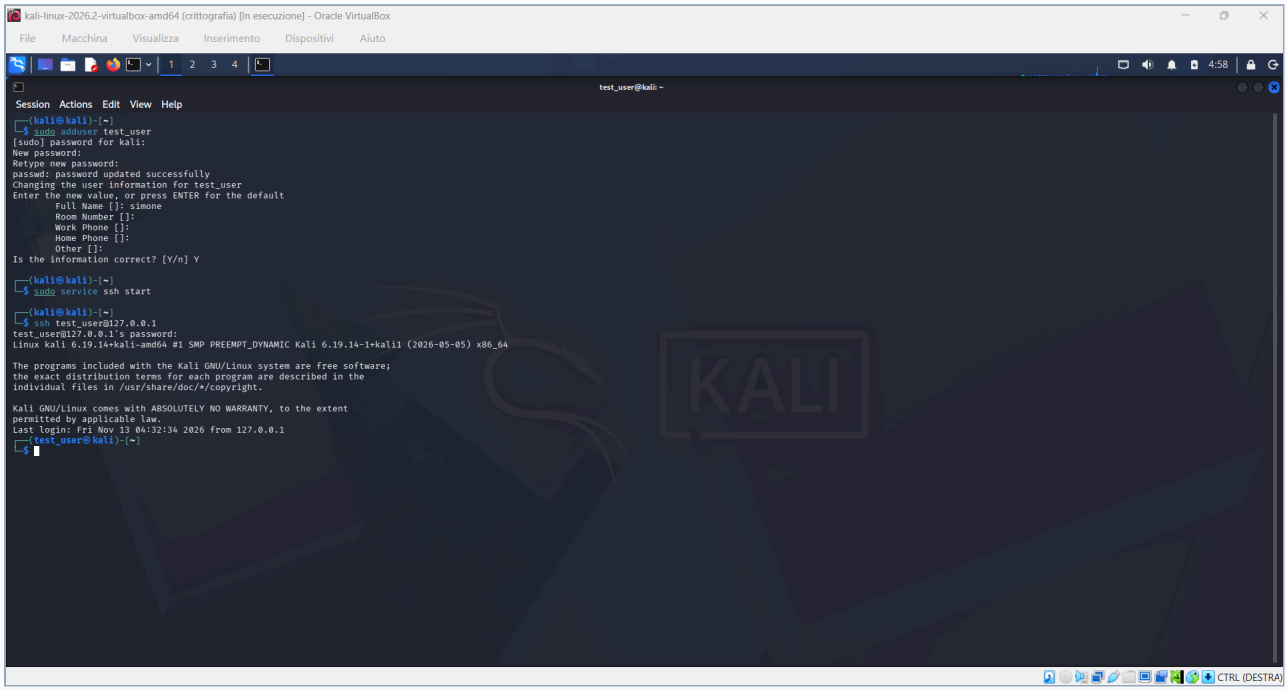


Figura 2: *avvio del servizio SSH e verifica del corretto funzionamento dell'autenticazione locale per l'utente* `test_user`.

Ottimizzazione dei dizionari e considerazioni prestazionali

Gestione delle wordlist

Durante la fase di test ho riscontrato che l'utilizzo di dizionari mastodontici (come quelli della raccolta *SecLists*) rende gli attacchi di rete estremamente lenti e pesanti. Per ottimizzare l'esecuzione ho creato file di testo mirati e ridotti (`users.txt` e `passwords.txt`), riducendo drasticamente i tempi di elaborazione.

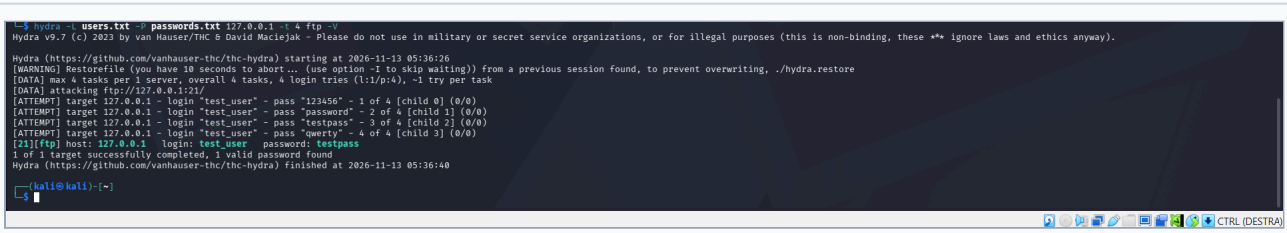


Figura 3: *controllo e verifica dei file di dizionario ottimizzati creati per velocizzare l'attacco.*

Ho quindi eseguito **Hydra** utilizzando i parametri principali:

- `-L users.txt`: specifica il file con la lista degli utenti da testare;
- `-P passwords.txt`: specifica il file con la lista delle password;
- `-t 4`: imposta 4 connessioni parallele per velocizzare il processo;
- `-V`: attiva la modalità *verbose* per monitorare ogni tentativo a schermo.

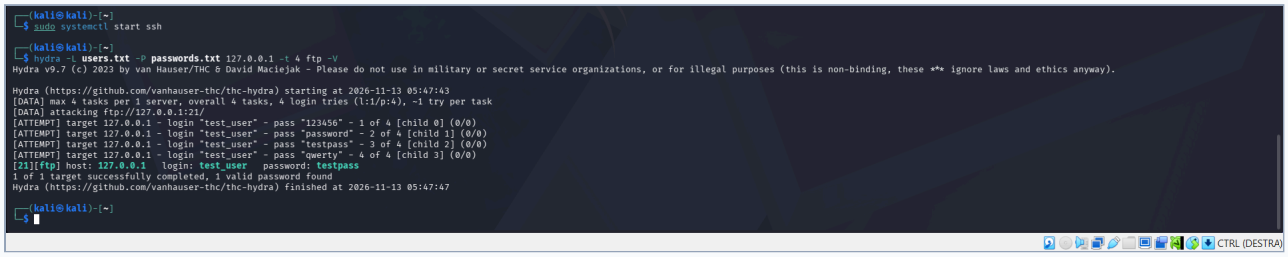


Figura 4: *esecuzione di Hydra sul protocollo SSH con output in tempo reale e individuazione della password corretta.*

4. Fase 2: installazione, configurazione e attacco sul servizio FTP

Nella seconda parte dell'esercitazione ho configurato un secondo servizio di rete, installando il demone **FTP** (*File Transfer Protocol*) tramite il pacchetto `vsftpd`.

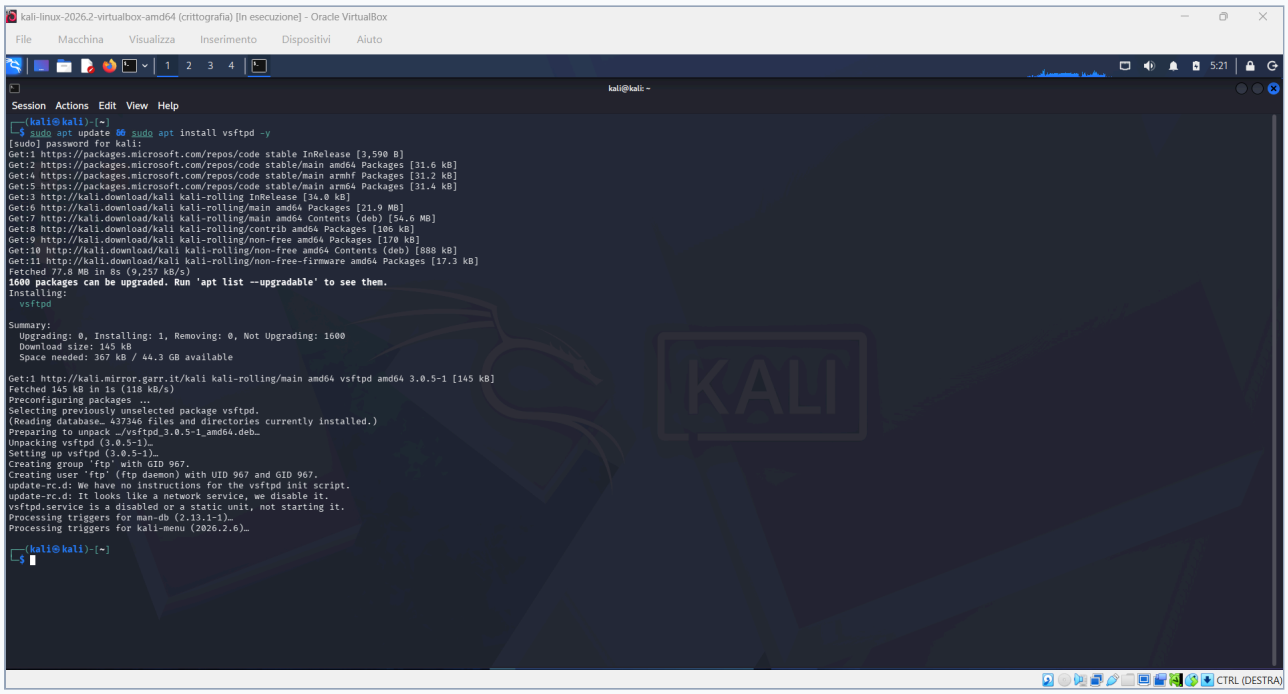


Figura 5: *aggiornamento dei repository e installazione del server FTP (`vsftpd`) su Kali Linux.*

Successivamente ho avviato il servizio e lanciato l'attacco mirato con Hydra sul demone `vsftpd`.

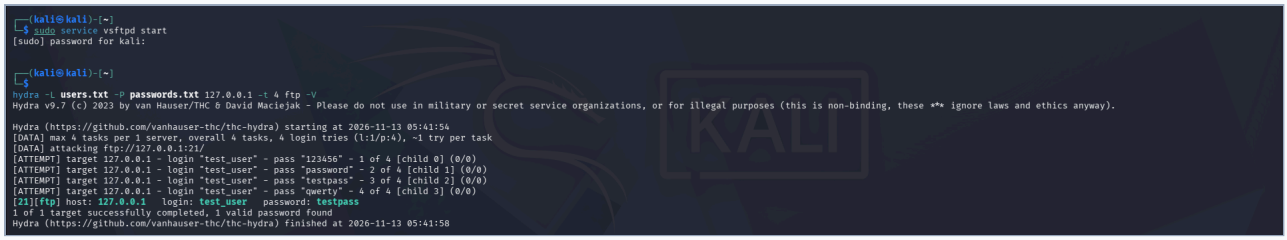


Figura 6: *attivazione del demone FTP ed esecuzione dell'attacco con dizionario mirato.*

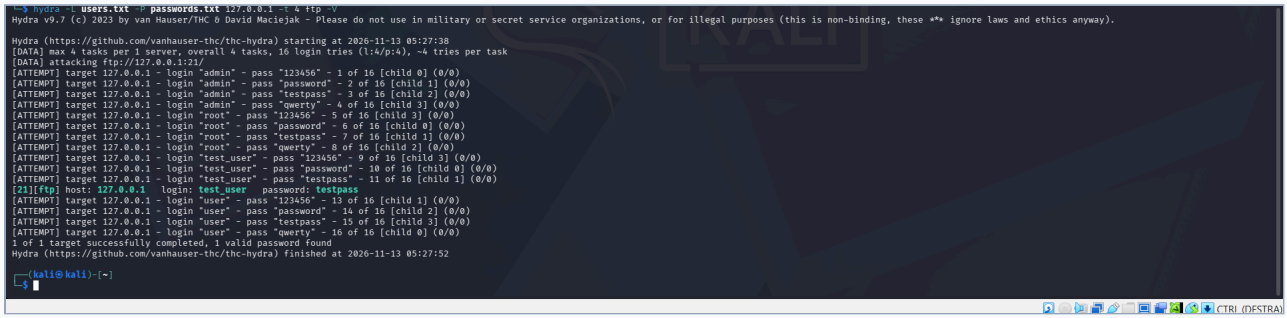


Figura 7: *individuazione con successo della password corretta associata all'utente target.*

5. Verifica post-sfruttamento (accesso agli account)

Una volta scoperte le credenziali corrette (`test_user` / `testpass`), ho verificato concretamente l'accesso ai servizi compromessi.

Accesso tramite SSH



Figura 8: *accesso riuscito via SSH e navigazione all'interno della cartella personale dell'utente compromesso.*

Accesso tramite FTP

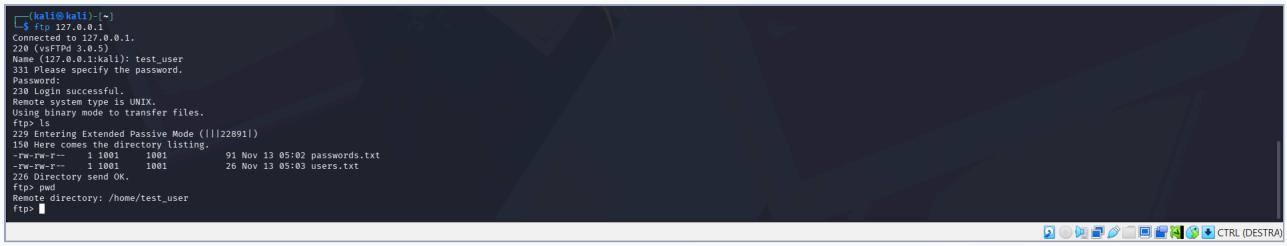


Figura 9: *connessione al server FTP con le credenziali scoperte e visualizzazione dei file remoti.*

6. Conclusioni e confronto tra i due protocolli

Questa esperienza ha evidenziato come gli attacchi a dizionario siano efficaci ma fortemente vincolati dai limiti di rete. Per superare la lentezza dei dizionari enormi negli attacchi online, un'alternativa professionale consiste nell'**attacco offline (Hash Cracking)**.

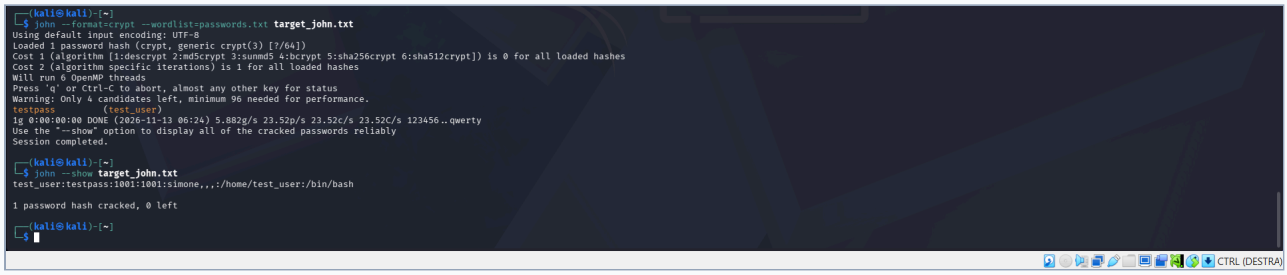


Figura 10: *estrazione dell'hash ed esecuzione dell'attacco offline con John the Ripper per recuperare la password in chiaro in modo fulmineo.*